Nmap.org Npcap.com Sectools.org Insecure.org

SECLISTS.ORG

Site Search

Full Disclosure mailing list archives

By Date By Thread

List Archive Search

[KIS-2025-11] Open Journal Systems <= 3.5.0-1 (NativeXmlIssueGalleyFilter.php) Path Traversal Vulnerability

From: Egidio Romano <n0b0d13s () gmail com>
Date: Tue, 23 Dec 2025 12:18:17 +0100

```
--------------------------------------------------------------------------------------------
Open Journal Systems <= 3.5.0-1 (NativeXmlIssueGalleyFilter.php) Path
Traversal Vulnerability
--------------------------------------------------------------------------------------------


[-] Software Links:

https://pkp.sfu.ca/software/ojs/
https://github.com/pkp/ojs


[-] Affected Versions:

Version 3.3.0-21 and prior versions.
Version 3.4.0-9 and prior versions.
Version 3.5.0-1 and prior versions.


[-] Vulnerability Description:

The vulnerability exists because user input passed to the "Native XML
Plugin" through the issue -> issue_galleys -> issue_galley ->
issue_file -> file_name tag of the imported XML file is not properly
sanitized before being used to set the "server-side file name", which
is later used as the final part of a variable which is used at in a
call to the writeFile() method without proper validation. This can be
exploited to write/overwrite arbitrary files on the web server via
Path Traversal sequences, potentially leading to, e.g., execution of
arbitrary PHP code (RCE).

Successful exploitation of this vulnerability requires an account with
permissions to access the "Import/Export" plugin ("Native XML
Plugin"), such as a "Journal Editor" or "Production Editor" user
account. Furthermore, in order to perform the following Remote Code
Execution (RCE) attack, the attacker should know or guess/disclose the
webserver path in which OJS is located (e.g.
/var/www/html/ojs-3.5.0-1).
```

```
[-] Solution:

Upgrade to versions 3.3.0-22, 3.4.0-10, 3.5.0-2, or later.


[-] Disclosure Timeline:

[21/10/2025] - Vendor notified
[24/10/2025] - Vendor fixed the issue and opened a public GitHub
issue: https://github.com/pkp/pkp-lib/issues/11973
[12/11/2025] - CVE identifier requested
[20/11/2025] - Version 3.3.0-22 released
[22/11/2025] - Version 3.4.0-10 released
[12/12/2025] - CVE identifier assigned
[29/11/2025] - Version 3.5.0-2 released
[23/12/2025] - Publication of this advisory


[-] CVE Reference:

The Common Vulnerabilities and Exposures program (cve.org) has
assigned the name CVE-2025-67890 to this vulnerability.


[-] Credits:

Vulnerability discovered by Egidio Romano.


[-] Original Advisory:

http://karmainsecurity.com/KIS-2025-11
```

_____
Sent through the Full Disclosure mailing list
https://nmap.org/mailman/listinfo/fulldisclosure
Web Archives & RSS: https://seclists.org/fulldisclosure/

⬅ By Date ➡ ⬅ By Thread ➡

Current thread:

[KIS-2025-11] Open Journal Systems <= 3.5.0-1 (NativeXmlIssueGalleyFilter.php) Path Traversal Vulnerability *Egidio Romano (Dec 27)*

Site Search

Nmap Security Scanner
Ref Guide
Install Guide
Docs
Download

Npcap packet capture
User's Guide
API docs
Download
Npcap OEM

Security Lists
Nmap Announce
Nmap Dev
Full Disclosure
Open Source Security
BreachExchange

Security Tools
Vuln scanners
Password audit
Web scanners
Wireless
Exploitation

About
About/Contact
Privacy
Advertising
Nmap Public Source License

Nmap OEM




